守 望 者 零 信 任

面向业务资源的安全接入与共享白皮书 (Version 1.1)

单业务级精准发布 • 多协议统一接入 • 资源授权与会话隔离

一、产品概述与核心价值

守望者零信任系统聚焦于企业内部业务资源的安全交付。系统以指定业务资源为授权对象，将资源发布端的目标 IP 与端口按需发布，并通过专属资源凭证建立访问链路。访问端可根据业务类型选择 HTTP/HTTPS、原生 TCP 或 Windows 远程桌面（RDP）接入方式，在统一工作台中使用已获授权的业务资源。

对于 Web 与原生 TCP 业务，访问端保留浏览器或本地客户端的使用习惯；对于 Windows 远程桌面资源，工作台提供直接进入远程桌面的入口，由 Windows 自带的 mstsc 建立远程桌面会话。

传统远程访问的现实痛点与守望者应对策略：

- **1. 过度授权与横向扩散**：传统方案通常接入整个网段，单点失陷可能波及全网。守望者将访问权限严格锁死在单一服务端口（IP:Port），完全隔离非授权设备。
- **2. 访问方式与权限边界：不同业务需要不同的使用方式。守望者按指定资源建立访问链路；对于 RDP，用户可获得目标 Windows 主机的远程桌面会话，但访问范围仍由发布的目标资源、远端账号权限及系统策略共同约束。**
- **3. 公网暴露与窃听威胁**：端口映射会将服务直接裸露于互联网探测中；第三方商业远控则存在数据过境云端被分析的合规风险。守望者采用无公网入站端口的主动通信架构，并全程执行双端强加密，杜绝第三方明文审查。

核心能力	实际收益

守望者网络安全实验室 © 版权所有

单业务级精准授权	权限精准锚定到单一端口，杜绝内网横向探测与越权漫游
端到端纯密文传输	业务数据在端侧完成加密封包，中转介质及第三方均无法还原明文
零公网服务暴露面	内部业务无需向互联网开放入站端口，规避自动化扫描与漏洞探测
原有应用无感使用	Web 通过浏览器、本地 TCP 客户端继续使用；Windows RDP 通过工作台直接进入远程桌面
0.0.0.0 局域网按需共享	接入端支持开启全网卡监听，局域网内其他协同设备无需安装客户端即可同步复用
独立安全凭证体系	每个业务资源绑定专属 Link ID 与口令，实现细粒度生命周期管理

二、核心角色与访问模型

守望者通过清晰的“发布-凭证-接入”逻辑，建立跨网络的业务管道：

- • **Visitor（资源访问端）：部署在需要使用业务的远程电脑上。用户输入对应资源凭证后，可按业务协议建立本地映射或启动远程桌面入口；访问范围限定于已授权的具体资源。**
- • **Visitor (资源访问端)**：部署在需要使用业务的远程电脑上。用户输入对应的资源凭证，系统即在本地创建虚拟端口映射，支持单机独享或局域网共享。
- • **Resource ID + Key (资源凭证)**：业务访问的鉴权核心。客户端登录仅提供基础入网权限，必须持有特定资源的 Link ID 与安全口令，才能建立对应业务的数据链路。

三、功能特性与业务体验

1. 端到端强加密：保障业务数据绝对私密

数据在传输全链路中受到严密保护：

守望者网络安全实验室 © 版权所有

- • **端侧自主加解密：**业务数据在离开发布端前，已在内存层完成高强度对称加密，解密过程仅在合法访问端执行。
- • **零知识传输通路：**中转网络与服务器仅负责密文流的物理调度，无法解析、嗅探或篡改业务报文。
- • **合规与隐私隔离：**彻底消除桌面流过境第三方商业云平台带来的合规隐患，保障财务、研发及核心数据库等机密资产的安全。

2. 多协议接入与统一工作台

访问端根据资源类型选择合适的使用方式。HTTP/HTTPS 业务通过浏览器访问本地映射入口；SSH、数据库及其他原生 TCP 业务由原有客户端连接本地映射端口；Windows 远程桌面资源则可在工作台点击“进入远程桌面”，由客户端调用 Windows 自带的 mstsc。

- • **Web 业务：在工作台使用“浏览器打开”，按本地映射地址访问。**
- • **原生 TCP 业务：通过本地映射端口连接，继续使用 SSH、数据库等原有客户端。局域网共享监听仅在可信、受控网络中按需启用。**

• Windows 远程桌面（RDP）：工作台提供“进入远程桌面”入口，调用 Windows 自带 mstsc；默认启用管理会话、全屏及本地磁盘映射选项，实际能力受远端系统策略与账户权限影响。

RDP 账号口令在访问端本机加密保存。启动每个 RDP 会话时，客户端创建独立的临时本地访问代理和会话凭据；会话结束后按连接状态回收临时资源。该机制用于隔离不同远程桌面会话，不改变原有资源发布、资源凭证鉴权及零信任隧道配置。

远程业务类型	本地映射地址示例	实际使用方式
内部 Web / OA / ERP	`127.0.0.1:18080`	浏览器直接打开；若开启 0.0.0.0，组内全员浏览器可同频访问
Linux 服务器运维 (SSH)	`127.0.0.1:18022`	使用系统终端、Xshell 或 Putty 直接连接回环端口
Windows 远程桌面 (RDP)	工作台直接启动 RDP 会话；	点击“进入远程桌面”，调用

守望者网络安全实验室 © 版权所有

	本地临时访问代理对应本条接入规则	Windows mstsc；默认管理会话、全屏及本地磁盘映射选项
核心业务数据库	`127.0.0.1:13306`	使用 Navicat、DBeaver、DataGrip 等专业管理软件顺畅操作
专有 TCP 业务协议	本地自定义分配端口	原生业务客户端指向本地端口正常工作

3. 业务隐形：消除互联网攻击面

系统基于出站安全连接技术构建通道。内部业务系统不需要公网 IP，也不需要在边界防火墙上配置任何入站端口开放规则。互联网扫描引擎（如 Shodan、Censys 等）无法感知内部资产的存在，从根源切断公网暴力破解和 0-Day 漏洞的主动探测。

4. 最小权限管控：锁定单一服务边界

访问者获得的仅仅是目标业务的报文收发权限。由于物理网络并未打通，访问端既无法向同网段其他主机发送数据包，也无法嗅探企业内部局域网广播，彻底阻断了黑客渗透中的横向移动路径。

四、典型应用方案

- **• 方案 1：企业日常协同与远程办公**

  办公室指定电脑发布内网 ERP 或知识库系统；异地办公员工在访问端完成本地端口映射后通过浏览器工作，使用体验与在办公室局域网内完全一致。

- **• 方案 2：外勤现场敏捷协作（0.0.0.0 团队复用）**

  技术交付团队在外场实施时，由一台设备作为 Visitor 连接公司内部集成测试环境，并绑定 0.0.0.0:8080。现场所有人员连接同一热点或局域网，即可同步调用开发接口，省去全员安装与账号配置成本。

守望者网络安全实验室 © 版权所有

- • 方案 3：外部厂商临时技术支持与排障

  第三方专家需要处理 Windows 主机时，Provider 可按需发布指定 RDP 资源；访问人员通过工作台进入远程桌面。若需排查 Linux 主机或数据库，则分别发布对应 SSH 或数据库 TCP 资源。技术服务结束后，发布端撤销对应资源授权。

- • 方案 4：关键生产数据库隔离运维

  开发人员需要查看核心库数据时，通过本地工具安全直连对应虚拟端口。即便员工处于公共网络环境，端到端密文封装技术也能有效抵御公共 WiFi 下的网络抓包与账密窃取。

1. 凭证分级流转：Link ID 与通信口令用于访问特定业务资源，应按最小特权原则安全交接；RDP 的 Windows 登录账号口令属于另一套凭据，应仅在可信访问端本机加密保存。

评估维度	传统 VPN 方案	商业远程桌面 (如向日葵)	公网端口映射 (NAT)	守望者零信任系统
访问控制粒度	整个局域网段	整台电脑桌面控制权	单个公开业务端口	**细粒度业务服务级（IP:Port）**
数据通信隐私	依赖 VPN 服务商配置	画面流经第三方商业云	通常为明文或依赖业务 SSL	**双端端到端强加密，第三方无法读取**
互联网暴露面	需开放 VPN 入口网关	依赖外部公有云中转	业务端口直接裸露公网	**零公网暴露面（服务完全隐形）**
横向扩散风险	极高（内网全开）	高（受控机易成跳板）	中（单点漏洞可能被攻破）	**杜绝扩散（物理隔离在单一服务）**
多端协同便利性	全员逐一配置账号规则	需购买多个商业并发席位	需配置专线与静态公网 IP	**支持 0.0.0.0 局域网单机接入整组复用**
原有软件兼容	易产生本地路由冲突	改变习惯（操作画面交互）	保持原有操作方式	**完全透明无感（映射为本地端口使用）**

守望者网络安全实验室 © 版权所有

六、安全运行与运维规范

- **1. 凭证分级流转：**Link ID 与口令具备访问特定业务的能力，应按最小特权原则一对一安全交接，严禁在未加密的公共聊天群中流转。
- **2. 本地监听与共享：普通单机访问优先使用 127.0.0.1；0.0.0.0 仅在可信、受控网络中按需使用。RDP 临时访问代理仅用于对应会话，不应作为局域网共享入口。**
- **3. 宿主安全不降低：**守望者负责网络边界隐身与通信加密，目标业务系统自身的弱口令排查、用户身份验证及内部越权防护仍应严格执行标准安全基准。

守望者：业务精准直达，网络隐形无感。

守望者网络安全实验室 © 版权所有